RESERVE BANK OF INDIA

Department of Regulation

Title: Master Direction on Information Technology Governance and Cyber Security Controls, 2026

Reference number: RBI/2026-27/31 DoS.CO.CSITEG/01/2026

Date: February 20, 2026

1. Applicability and Scope

1.1 These Directions shall apply to all Regulated Entities operating critical systems, and each entity shall appoint a Chief Information Security Officer who will be responsible for the cyber security posture and incident response readiness of the organisation.

1.2 Regulated Entities shall maintain a board-approved Information Security policy covering all internet-facing systems, privileged accounts, and remote administrative access, and the policy shall be reviewed at least once every twelve months.

2. Incident Reporting and Controls

2.1 Regulated Entities shall report all cyber security incidents to the Reserve Bank within 6 hours of detection, and a detailed root-cause report shall be submitted within 30 days of containment of the incident.

2.2 Regulated Entities shall enforce multi-factor authentication for all privileged accounts and remote administrative access, and single-factor access to critical systems shall be disabled within 60 days of issuance of these Directions.

2.3 Regulated Entities shall retain immutable audit logs of all access to sensitive customer information for a minimum period of twelve months, and logs shall be reviewed for anomalies on a daily basis by the security operations function.

2.4 Regulated Entities shall conduct vulnerability assessment and penetration testing of internet-facing systems at least once every six months, and critical vulnerabilities shall be remediated within 15 days of identification.

2.5 Regulated Entities shall implement network segmentation isolating critical systems from general office networks, and all inter-zone traffic shall pass through inspected gateways with deny-by-default rules reviewed every 90 days.

3. Governance and Review

3.1 The Board of Directors shall constitute an IT Strategy Committee that meets at least once every three months, and the Chief Information Security Officer shall report incident trends and control maturity to the committee.

3.2 Regulated Entities shall conduct a cyber crisis simulation exercise at least once every twelve months covering ransomware and data-breach scenarios, and gaps identified shall be remediated within 90 days with evidence retained for supervisory review.